



Rapport d'analyse de bugs

Landing Page Generator — CMS Multi-École (Reetain)

Analyse statique de ~14 500 lignes · Backend, API, librairies, éditeur, formulaires, dashboard, SQL · 19 juillet 2026

3 CRITIQUES	25 MAJEURS	24 MINEURS	52 TOTAL
----------------	---------------	---------------	-------------

Bugs critiques — priorité absolue

- CRIT-1** Fuite de secrets — le fichier .env et tout le code source sont téléchargeables

server.js:2659

Le serveur de fichiers statiques fait `filePath = '.' + pathname` sans aucune protection. `GET /.env` renvoie les clés Supabase / SFMC / Gemini ; `/server.js` , `/lib/sfmc.js` , `/schools.json` exposent le code source. Path traversal (`..`) également possible.

Correctif : servir depuis un dossier `public/` dédié, appliquer `path.normalize` , refuser les dotfiles et `...` .
- CRIT-2** Collision de customerKey SFMC entre écoles → écrasement / suppression de pages

lib/sfmc.js:63-64

`customerKeyFor()` retire le préfixe école mais ne le remet pas (contrairement à `comp-{id}-` / `form-{id}-`). `school-efap__Brochure` et `school-brassart__Brochure` produisent la même clé → publier l'une écrase l'autre ; dépublier l'une supprime l'autre.

Correctif : intégrer le `schoolId` dans le `customerKey`.
- CRIT-3** XSS / injection dans le code des formulaires générés

js/form-generator.js:485-531

Labels, messages, `formName` , `deKey` injectés sans échappement dans le HTML et l'AMPscript envoyés à SFMC (Cloud Pages) → XSS stocké + rupture de chaîne AMPscript sur un guillemet.

Correctif : `escapeHtml` pour le HTML, doubler les `"` en AMPscript.

Bugs majeurs — corruption de données / fonctionnalités cassées

Backend & jobs asynchrones

- MAJ** Double création de version à chaque sauvegarde

api/router.js:670 + api/cron.js:74

La version est créée en synchrone puis re-crée par le worker. `version_number` incrémenté 2× par save, historique pollué.
- MAJ** Jobs cron traités deux fois (pas de claim atomique)

api/cron.js:13-30 · server.js:2695

Sélection des jobs pending puis passage en processing non atomique + setInterval sans garde de ré-entrance → double publication SFMC / doublons de Data Extensions.
- MAJ** Race sur version_number

api/content.js:315-316

`SELECT max+1` non atomique → violation de la contrainte unique → save en 500 sous accès concurrent.
- MAJ** page_group_id traité comme un nom de projet

server.js:915 · api/router.js:619

Casse le regroupement bilingue (bascule de langue) des traductions.

MAJ Statut incohérent legacy ↔ structuré

api/router.js:803-834

Publish/unpublish ne met pas à jour `pages.status` → une page peut afficher published d'un côté et draft de l'autre.

MAJ Transfert d'école incomplet

api/schools.js:343

Retourne `0` au lieu de `{count,pages}` → NaN dans les logs ; noms divergents entre Projects et pages structurées (page orpheline) ; école « de base » jamais réellement supprimée.

MAJ supabaseRequest ne vérifie pas response.ok

server.js:622-633

Une erreur PostgREST est renvoyée au client en HTTP 200 ; `JSON.parse` non protégé (crash sur 502/504).

MAJ Injection de filtre PostgREST

server.js:1867,1882

`schoolId` / `id` non encodés dans les routes `/api/forms/*`.

Frontend & éditeur

MAJ Parsing du nom de projet cassé si le titre contient « __ »

js/app.js:289,3279,3331,3540

Titre tronqué, langue faussée.

MAJ Langue toujours affichée « FR » dans le dashboard

js/app.js:2932 vs 3391

Nouveaux projets sauvés sans suffixe de langue, mais le dashboard lit `parts[1] || 'FR'`.

MAJ Statut « Publié » perdu à l'ouverture d'une page structurée

js/app.js:316-327,1193

Le badge repasse à « Brouillon », le bouton Dépublier disparaît.

MAJ fetch sans res.ok + suppose un tableau

js/app.js (multiples) • ai-assistant.js:61 • form-generator.js:423-458

TypeError silencieux, faux « succès » affichés à l'utilisateur.

MAJ Promesse jamais résolue (Form Builder figé)

js/app.js:2566

`new Promise(async...)` sans `resolve` dans le catch → bouton bloqué en cas d'échec réseau.

MAJ IDs de messages IA en collision (Date.now)

js/ai-assistant.js:197

La mauvaise bulle est mise à jour à chaque envoi (spinner bloqué).

MAJ Google Fonts inutilisables

js/fonts.js:63-70

`fontById` ne cherche que dans `PROJECT_FONTS` → toute école en Google Font retombe sur Gotham.

MAJ Validation formulaire : checkbox requise jamais validée

blocks/forms/shared/form-validators.js:100-105

`field.value` non vide même décochée → la validation « requis » passe toujours.

MAJ Consentement RGPD forcé même si optionnel

form-validators.js:127-144

Le flag `required:false` de `buildRgpdBlock` est ignoré.

MAJ Téléphone international rejeté

blocks/forms/shared/event-form.js:748

`+33612345678` rejeté car le « + » n'est pas retiré avant le test regex.

MAJ XSS stockés multiples

ai-assistant.js:92 · component-builder.js:325+ · pages-dashboard.html:598 · school-selector.html:1295

Titres de conversation, contenu component-builder, toast dashboard ; `escHtml` n'échappe pas l'apostrophe dans les `onclick`.

Dashboard & base de données

MAJ Logo d'école écrasé à chaque enregistrement

school-selector.html:1937

Le champ `#school-logo` n'existe pas → `logo:''` envoyé à chaque PUT.

MAJ Champ SEO impossible à vider

pages-dashboard.html:1656,1708

La fusion ignore les valeurs vides → l'ancienne valeur réapparaît à la réouverture.

MAJ Colonnes DB manquantes

database/scalable-schema.sql:159-174

Le formulaire envoie `colorHeader`, `logo`, `customHeadCode` ... absents de la table Schools → perte silencieuse.

MAJ Unicité de slug cassée quand folder_id / parent_id est NULL

scalable-schema.sql:69,50

En Postgres les NULL sont distincts → doublons de slug → collision d'URL publique.

MAJ ON DELETE SET NULL orpheline les traductions

scalable-schema.sql:65

Supprimer l'original rend les traductions invisibles et non regroupables.

Bugs mineurs — robustesse & cohérence (extrait)

- **schemaLd JSON-LD injecté sans échappement** — `lib/api-shared.js:48`, `server.js:371` : `</script>` casse la page.
- **<html lang="fr"> codé en dur** — `lib/api-shared.js:55` : mauvais SEO/accessibilité des pages EN/ES.
- **Token SFMC : pas de dédup de concurrence** — `lib/sfmc.js:92` : double appel `/v2/token` → risque 429.
- **Aucun fetch n'a de timeout/retry** (SFMC, Supabase, Gemini) → un appel qui pend bloque le job.
- **Pagination SOAP campus ignorée** (MoreDataAvailable) — `lib/sfmc.js:975` : campus perdus au-delà d'un batch.
- **hexToRgb ne gère pas #fff** — `server.js:310`, `js/app.js:2050` → couleur de marque par défaut.
- **Accès Gemini non protégé** `data.candidates[0]...` — `server.js:2113` : crash si réponse bloquée (SAFETY).
- **Corruption UTF-8 multi-octets** — `server.js:2049,2464` (`body += chunk` sans `Buffer.concat`).
- **Slug avec point traité comme fichier** — `server.js:2576` : `/formation-3.0` → 404.
- **Clé Gemini dans l'URL** — `lib/translate.js:97` : fuite possible dans les logs.
- **Code mort** : `openActivationModal` non câblé (pages-dashboard.html:1397), `performDirectSave` (app.js:2666), handlers/routes dupliqués (server.js:2209,2226).
- **createDataExtension 409 → faux succès** (lib/sfmc.js:683), **colonne SubmissionDate manquante + InsertDE par nom** (form-generator.js:499), **noms de champs DE non uniques** (form-generator.js:215).

- **Migrations non autonomes** (gen_random_uuid sans pgcrypto), **index page_group_id absent du schéma de base**, vercel.json : rewrite /api/cron no-op + outputDirectory ".".
- **Upload image** : type/taille non validés côté campus (js/campus.js:248), ObjectURL jamais révoqué (js/export.js:104), SVG sans dimensions → canvas 1×1 (js/image-upload.js:48).
- **localStorage sans try/catch** — risque de QuotaExceededError non intercepté sur grosses pages (js/app.js).

Thèmes récurrents (racines communes)

1. **Absence d'échappement systématique** → XSS/injection dans ~8 endroits. Un helper `escapeHtml` / `escapeAttr` / `escapeAmpscript` centralisé règle la majorité.

2. **fetch sans res.ok ni Array.isArray** → erreurs masquées et faux succès un peu partout côté frontend.

3. **Deux modèles de stockage désynchronisés** (legacy Projects ↔ structuré pages) → statut, nom, versions, groupes divergent.

4. **Opérations concurrentes non protégées** (jobs cron, version_number, token SFMC).

Recommandation

Les 3 corrections les plus rentables : **(a)** sécuriser le service de fichiers statiques (CRIT-1) · **(b)** intégrer le `schoolId` dans le customerKey SFMC (CRIT-2) · **(c)** un helper d'échappement partagé (couvre CRIT-3 + plusieurs XSS majeurs).